

Otizm Destek Platformu — Profesyonel Yayına Geçiş Raporu

Hazırlanma tarihi: 15 Temmuz 2026 **Kapsam:** Teknik inceleme · Güvenlik & gizlilik (KVKK) · Erişilebilirlik · Maliyet analizi · Yayın yol haritası
Yöntem: Rapor projenin **gerçek kaynak kodundan** çıkarılmıştır. Kodda olmayan hiçbir özellik varsayılmamıştır. Emin olunmayan yerler açıkça belirtilmiştir.

İçindekiler

- Teknik İnceleme
- Demo → Profesyonel Geçiş Tablosu
- Otizm Platformuna Özel Güvenlik & Gizlilik (KVKK)
- Erişilebilirlik Analizi
- Güncel Maliyet Araştırması — Kur & Kaynaklar
- Frontend Yayınlama
- Backend Sunucu Maliyeti
- Veritabanı Maliyeti
- Domain ve DNS
- SSL, CDN ve Güvenlik
- Dosya ve Görsel Depolama
- E-posta Sistemi
- Kimlik Doğrulama
- Yönetim Paneli
- Analitik, Loglama, Hata Takibi
- SEO
- Yedekleme ve Felaket Kurtarma
- Test ve Yayın Süreçleri
- Toplam Maliyet Tablosu
- Üç Bütçe Senaryosu
- Nereden Satın Almalıyım?
- Adım Adım Yayınlama Rehberi
- Nihai Öneri

Döviz kuru notu: Tüm dönüşümlerde **1 USD = 47,0 TL** kullanıldı. Kaynak: TradingEconomics — USD/TRY, tarih **15 Temmuz 2026** (o gün 47,04; aylık ortalama 46,67). EUR fiyatları için **1 EUR ≈ 51 TL** (tahmini) kullanıldı. Kesin olmayan fiyatlar "tahmini" olarak işaretlendi.

1. Teknik İnceleme

1.1 Frontend

Konu	Tespit
Teknoloji	React 19.2 + Vite 8 + TypeScript 6 + TailwindCSS 4 (saf SPA, SSR yok — Next.js/Nuxt kullanılmıyor)
Yönlendirme	<code>react-router-dom 7.14</code> — client-side routing, lazy-loaded sayfalar (<code>lazyNamed</code>), rol bazlı korumalı rotalar (<code>RoleRoute</code> , <code>AdminRoute</code>)
Durum yönetimi	<code>zustand 5</code> (persist ile), <code>@tanstack/react-query 5</code> (sunucu durumu)
Form	<code>react-hook-form 7</code> + <code>zod 4</code> + <code>@hookform/resolvers</code> — şema tabanlı doğrulama
API bağlantısı	<code>axios 1.15</code> ; prod'da <code>vercel.json</code> <code>rewrite</code> ile <code>otizm-backend.onrender.com</code> 'a proxy
Gerçek zamanlı	<code>@stomp/stompjs</code> + <code>sockjs-client</code> (WebSocket mesajlaşma/bildirim)
Oturum	JWT access (15 dk) + refresh (7 gün); token localStorage 'da (<code>authStore</code> / <code>zustand persist</code> <code>auth-storage</code>)
Grafik / ikon	<code>recharts 3</code> ; <code>lucide-react</code> ; <code>react-qr-code</code> (acil durum profili QR)
PWA	<code>manifest.json</code> , <code>sw.js</code> service worker, <code>offline.html</code> , push (VAPID)
Test	Vitest + Testing Library + Playwright (e2e klasörü mevcut)
Responsive/mobil	Tailwind mobile-first; <code>viewport-fit=cover</code> , <code>apple-touch-icon</code> , PWA — mobil uyumlu
Env kullanımı	<code>VITE_*</code> değişkenleri (ör. <code>VITE_VAPID_PUBLIC_KEY</code> build-arg olarak veriliyor)

Frontend güvenlik notları: Token `localStorage` 'da tutuluyor → XSS'e maruz kalırsa çalınabilir (httpOnly cookie daha güvenli olurdu). Google Fonts harici yükleniyor (`fonts.googleapis.com`) — gizlilik/performans açısından self-host edilebilir.

1.2 Backend

Konu	Tespit
Teknoloji	Spring Boot 3.3.5, Java 21 (Maven)
Mimari	Katmanlı: <code>controller</code> / <code>service</code> / <code>repository</code> / <code>model</code> / <code>dto</code> / <code>security</code> / <code>config</code> / <code>exception</code> / <code>util</code> / <code>websocket</code>
Ölçek	60+ Controller, 61 Service, 80+ Entity — demo değil, olgun bir uygulama
REST	Standart <code>@RestController</code> , tutarlı <code>ApiResponse<T></code> sarmalayıcı
DB bağlantısı	PostgreSQL + Hibernate/JPA, HikariCP (max pool 10), <code>ddl-auto=validate</code> (güvenli), <code>open-in-view=false</code> (iyi)
Güvenlik	Spring Security + stateless JWT (<code>jjwt 0.12.6</code>), BCrypt parola, <code>@EnableMethodSecurity</code>
Roller	<code>PARENT</code> , <code>EXPERT</code> , <code>ADMIN</code> , <code>TEACHER</code> (enum) — rol bazlı yetkilendirme
Refresh token	DB'de saklanıyor, <code>used</code> bayrağı ile rotasyon; parola sıfırlama token'ı (<code>PasswordResetToken</code>)
Rate limiting	<code>@RateLimit</code> anotasyonu + <code>RateLimitInterceptor</code> (Redis tabanlı, Redis yoksa in-memory fallback)
Hata yönetimi	<code>GlobalExceptionHandler</code> (merkezi)
Doğrulama	<code>spring-boot-starter-validation</code> (Jakarta Bean Validation)
Loglama	SLF4J; Spring Security log seviyesi WARN
Dosya yükleme	Yerel disk, UUID adı, tip+uzantı beyaz listesi (jpg/png/webp/gif/pdf/txt), 10MB limit, path traversal koruması
E-posta	Spring Mail SMTP (SendGrid/Mailgun)
API dokümanı	SpringDoc OpenAPI + Swagger UI (sadece ADMIN erişilebilir — iyi)
İzleme	Actuator + Micrometer + Prometheus
Test	18 test dosyası — unit + integration (Testcontainers PostgreSQL + H2)

1.3 Üçüncü Taraf Servisler (kodda tespit edilenler)

Servis	Kullanım	Ücretsiz limit	Prof. maliyet
Google Gemini (gemini-2.5-flash-lite)	Chatbot, AI içgörüler, BEP rapor taslağı	Ücretsiz kota + düşük ücret	flash-lite çok ucuz; ~\$0-5/ay tahmini düşük hacimde
Firebase Cloud Messaging	Mobil push bildirim	Tamamen ücretsiz	\$0
Web Push (VAPID)	Tarayıcı push	Kendi anahtarınız, ücretsiz	\$0
SMTP (SendGrid/Mailgun)	E-posta doğrulama, parola sıfırlama	Bölüm 12	Bölüm 12
Harita	Kodda enlem/boylam alanları var; harici harita API'si tespit edilmedi — muhtemelen sadece mesafe hesaplama	—	—
Google/sosyal giriş	Kodda tespit edilmedi (yalnızca e-posta/parola)	—	—
Ödeme sistemi	Kodda yok	—	—
Analitik / hata takibi	Kodda yok (Sentry/GA entegrasyonu bulunmuyor)	—	Bölüm 15

Not: Firebase Admin SDK backend'de mevcut ama **sadece FCM push** için — Firebase Authentication kullanılmıyor.

1.4 Veritabanı

- Tür:** PostgreSQL. Şema **Flyway** ile yönetiliyor (**V1** → **V42**, düzenli versiyonlama — çok iyi).
- İlişkiler:** Zengin ilişkisel model (User–Child–Appointment–ClinicalDataShare–Expert vb.). UUID birincil anahtarlar.
- İndeksler:** `V15__operational_indexes.sql` operasyonel indeksler ekliyor — temel bir performans çalışması yapılmış. Büyüdükçe sorgu bazlı ek indeks gerekebilir.
- Hassas veri saklama:** Parolalar BCrypt (iyi). Ancak **sağlık/gelişim verileri (davranış günlüğü, duyuşal profil, tarama sonuçları, klinik notlar) düz metin** olarak saklanıyor — alan bazlı şifreleme **yok** (kritik bulgu, Bölüm 2/3).
- Veri kaybı riski:** Yüklenen dosyalar **yerel diskte** (Bölüm 11). Render gibi efemeral disk kullanan platformda yeniden başlatmada **dosyalar kaybolur**. DB için yönetilen yedekleme şart.

2. Demo → Profesyonel Geçiş Tablosu

Alan	Mevcut Durum	Tespit Edilen Sorun	Yapılması Gereken	Öncelik
Güvenlik / Şifreleme	ENCRYPTION_KEY tanımlı ve startup'ta doğrulanıyor ama kodda hiç kullanılmıyor	Hassas sağlık verileri DB'de düz metin	JPA AttributeConverter ile alan bazlı AES-GCM şifreleme	Kritik
Dosya güvenliği	/api/upload/** GET permitAll, dosyalar yerel diskte	Yetki kontrolü yok (capability-URL); disk efemeral, yedeksiz	Object storage (R2/S3) + imzalı URL + sahiplik kontrolü	Kritik
Frontend oturum	JWT localStorage 'da	XSS'e maruz	httpOnly cookie'ye geçiş veya sıkı CSP	Yüksek
SEO	robots.txt/sitemap.xml yok, per-sayfa meta yok, SPA	İçerik indekslenmiyor	Meta yönetimi + sitemap + (gerekirse SSR/prerender)	Yüksek (halka açık içerik için)
Hata takibi	Yok	Prod hataları görünmez	Sentry ekle (FE + BE)	Yüksek
Analitik	Yok	Kullanım ölçülemez	Plausible / GA4	Orta
Backend	Render ücretsiz/starter	Ücretsiz katman 15 dk sonra uyur, soğuk başlangıç	Ücretli katman veya Hetzner VPS	Yüksek
Veritabanı yedekleme	Manuel yedek endpoint eklenmiş	Otomatik/dış yedek yok	Yönetilen DB otomatik yedek	Kritik
Varsayılan secret'lar	application.yml 'de dev varsayılanları	Prod'da StartupSecurityCheck engelliyor (iyi) ama secret'lar rotasyona muhtaç	Tüm secret'ları güçlü ve gizli tut	Yüksek
CI/CD	3 GitHub Actions workflow var (backend-ci, frontend-ci, deploy→GHCR)	Otomatik sunucu deploy DEPLOY_ENABLED kapalı	Staging + otomatik deploy aktifle	Orta

Değerlendirilen alanların özeti:

- Kimlik doğrulama/etkilendirme/roller:** Sağlam (JWT + BCrypt + method security + 4 rol + korumalı rotalar). ✔
- Admin paneli güvenliği:** Frontend AdminRoute + backend rol kontrolü + Swagger yalnızca ADMIN. İyi. ✔
- SQL injection:** JPA/parametrelili sorgular → düşük risk. ✔
- XSS:** React varsayılan kaçıışı korur; token localStorage riski var. Orta.
- CSRF:** Stateless JWT + CSRF disable → uygun (cookie tabanlı olmadığı için). ✔
- Rate limiting / bot koruması:** Rate limit var; **CAPTCHA yok** (kayıt/iletişim formu için Turnstile önerilir).
- HTTPS:** Vercel + Render/Cloudflare otomatik TLS. ✔

3. Otizm Platformuna Özel Güvenlik & Gizlilik (KVKK)

Bu platform **özel nitelikli kişisel veri** (KVKK m.6 — sağlık verisi) ve **çocuk verisi** işliyor. Kodda Child (ad, doğum, cinsiyet, fotoğraf), SensoryProfile, ScreeningResult, ClinicalDataShare, BepReport, DevelopmentNote, uzman-danışan mesajlaşması (Message, Conversation) mevcut. Bu, en yüksek gizlilik yükümlülüğü kategorisidir.

Kodda mevcut olumlu unsurlar:

- kvkk_consent + kvkk_consent_date alanları (User) — rıza kaydı tutuluyor.
- ClinicalDataShare — ebeveynin uzmanla **hangi veriyi paylaşacağını seçmesi** + iptal (REVOKED) + süre (expiresAt). Çok iyi bir gizlilik-tasarımı örneği.
- Yasal metin sayfaları mevcut: /kvkk, /gizlilik, /kullanım-sartlari, /tibbi-uyari (tıbbi uyarı) — PublicInfoPage içinde.
- AuditLog entity + admin denetim kaydı sayfası (AdminAuditLogPage) — yönetici erişim kayıtları var.
- Hesap pasifleştirme (is_active) mevcut.

Kritik eksikler / dikkat gerektirenler:

- Şifreleme yok:** Sağlık verileri düz metin. Özel nitelikli veri için **at-rest şifreleme** güçlü tavsiye.
- Dosya erişimi:** Rapor/belge yüklemeleri herkese açık URL ile sunuluyor — imzalı/etkili erişime geçilmeli (Bölüm 11).
- Çocuk verisi & veli onayı:** Açık rıza akışının çocuğun özel nitelikli verisi için ayrıca ve granüler alındığından emin olun.
- Veri dışa aktarma & silme (KVKK m.11 / GDPR):** Kod tarafında kullanıcının **kendi verisini dışa aktarma** ve **"hesabımı sil" self-servis akışı** tespit edilemedi — yalnızca admin tarafı silme var. Kullanıcıya dönük veri taşınabilirliği + silme talebi akışı eklenmeli.
- Veri saklama süresi:** Otomatik anonimleştirme/silme politikası yok — saklama süreleri tanımlanmalı.

Tıbbi sorumluluk metni: Platformda AI chatbot, BEP taslağı, tarama sonuçları ve gelişim takibi var. Bunlar **tıbbi teşhis/tedavi izlenimi** yaratabilir. /tibbi-uyari sayfası mevcut (iyi); ancak AI chatbot çıktısının yanında, tarama sonucu ekranında ve BEP taslağında **görünür uyarı** bulunmalı. Metin özü: "Bu platform bilgilendirme amaçlıdır, profesyonel sağlık/egitim hizmetinin yerine geçmez; teşhis ve tedavi için uzmana başvurun."

⚠ Hukuki not: Bu bir hukuki görüş değildir. KVKK VERBİS kaydı, özel nitelikli veri işleme şartları, açık rıza metinleri, çocuk verisi ve aydınlatma yükümlülüğü için **KVKK uzmanı/avukat** ile çalışılması zorunludur. Sağlık verisi işleyen bir platform için bu masraf ihmal edilmemeli.

4. Erişilebilirlik Analizi

Hedef kitle (özel gereksinimli bireyler, aileler, eğitimciler) nedeniyle en kritik başlıklardan biri.

Kod tabanlı ölçümler (pozitif):

- aria-label / aria-* : **146 kullanım**
- 'lerin **24/24'ünde alt** — %100 kapsama **✓**
- <label> / htmlFor : **154 kullanım** (form etiketleme güçlü)
- role= : 12; lang="tr" HTML kök seviyesinde **✓**

Erişilebilirlik **ciddiye alınmış** — çoğu demo projeden çok ileride. Yine de kod-seviyesi tarama tam denetimin yerini tutmaz; eksik/riskler:

Sorun	Öneri	Öncelik
prefers-reduced-motion yalnızca 1 yerde	Tüm animasyon/geçişlerde hareket azaltma desteği	Yüksek
SPA'da rota değişiminde odak yönetimi belirsiz	Rota değişince <h1> /main'e odak + aria-live başlık duyurusu	Yüksek
Renk kontrastı otomatik doğrulanmamış	Lighthouse/axe ile WCAG 2.1 AA kontrast taraması	Yüksek
Klavye ile tam gezinme test edilmemiş	Modal/menü/forum bileşenlerinde focus-trap + tab sırası testi	Orta
Video/ses içeriği altyazı durumu	İçerik eklenirse altyazı + transkript zorunlu	Orta (içerik varsa)
Ekran okuyucu testi	NVDA/VoiceOver ile manuel akış testi	Yüksek

Yapılacak: @axe-core/playwright ile e2e erişilebilirlik testi + Lighthouse CI. Manuel ekran okuyucu turu. (Maliyet: yalnızca zaman; araçlar ücretsiz.)

5. Güncel Maliyet Araştırması — Kur & Kaynaklar

- Kur:** 1 USD = 47,0 TL — TradingEconomics USD/TRY, 15 Temmuz 2026. EUR ≈ 51 TL (tahmini).
- Tüm fiyatlar resmi fiyatlandırma sayfalarına dayandırılmıştır; ilk yıl / yenileme farkları belirtilmiştir.
- Kaynak listesi raporun sonundadır.

6. Frontend Yayınlama

Proje saf statik SPA (Vite build → statik dosyalar; SSR yok). **Her statik host'ta çalışır** — SSR sunucusuna gerek yok. Büyük avantaj (ucuz + hızlı + CDN).

Servis	Ücretsiz Paket	Aylık Ücret	Trafik	Avantaj	Dezavantaj
Cloudflare Pages	Çok cömert	\$0	Sınırsız bandwidth	En iyi CDN, ücretsiz, TR'ye yakın	Build dakika limiti
Vercel	Hobby (ticari değil!)	Pro \$20/kullanıcı	Hobby 100GB / Pro 1TB	DX mükemmel, mevcut kurulum	Hobby ticari kullanımda değil; aşım \$0,15/GB
Netlify	100GB	\$19	100GB→1TB	Kolay	Vercel'e benzer fiyat
Firebase Hosting	10GB depo	Kullanım bazlı	—	Google ekosistemi	Ölçekte pahalı olabilir
DO App Platform	3 statik site	~\$0 statik	—	DO ekosistemi	Gereksiz
Render Static	Var	\$0	100GB	Backend ile aynı yer	CDN Cloudflare kadar iyi değil
Kendi VPS + nginx	—	VPS'e dahil	VPS trafiği	Dockerfile.prod + nginx.conf hazır	TLS/CDN/güncelleme sizde

⚠ **Önemli:** Vercel **Hobby (ücretsiz) planı ticari kullanıma kapalıdır**. Gerçek kullanıcıya açılan platform için Vercel'de kalmak isterseniz **Pro (\$20/ay)** gerekir.

Öneri: Cloudflare Pages. Ücretsiz, sınırsız trafik, güçlü global CDN, Cloudflare DNS/WAF/Turnstile ile aynı panelde. Mevcut `vercel.json` rewrite mantığı Cloudflare Pages'te `_redirects` /Functions ile küçük bir uyarlamayla karşılanır. Ticari kısıt yok.

7. Backend Sunucu Maliyeti

Backend Docker imajı (`backend/Dockerfile` , GHCR'a push ediliyor). Spring Boot + JVM → rahat çalışması için **en az ~1GB RAM** gerekir.

Servis	Aylık	RAM/CPU	Disk	Trafik	Yedek	Konum/TR	Docker	Ücretsiz
Hetzner CX22	€3,79 (~178 TL)	2 vCPU / 4GB	40GB	20TB	Snapshot ~€1,3/ay	Almanya/Finlandiya, TR'ye iyi	✓	Hayır
Hetzner CX32	€6,80 (~347 TL)	4 vCPU / 8GB	80GB	20TB	"	"	✓	Hayır
Render Starter	\$7 (~329 TL)	0.5 CPU / 512MB	—	Dahil	Otomatik (ücretli DB'de)	ABD/Frankfurt	✓	Var (uyur)
Render Standard	\$25 (~1.175 TL)	1 CPU / 2GB	—	Dahil	"	"	✓	—
Railway	~\$5+ (kullanım)	Esnek	Esnek	Dahil	—	ABD/EU	✓	\$5 kredi
Fly.io	~\$5–10	shared/1GB	Volume ücretli	Dahil	—	Frankfurt (TR'ye iyi)	✓	Sınırlı
DigitalOcean Droplet	\$6–12	1GB→2GB	25–50GB	1–2TB	+\$1,2/ay	Frankfurt	✓	Hayır
AWS/GCP/Azure	~\$15–40+	değişken	değişken	Egress pahalı	Var	Frankfurt	✓	12 ay sınırlı
TR VPS (Natro/Turhost)	~150–400 TL	1–2 vCPU/2–4GB	SSD	Sınırlı	Değişir	Türkiye — en düşük gecikme	✓	Hayır

Kullanıcı senaryolarına göre tahmini backend ihtiyacı:

Aylık aktif kullanıcı	Tahmini ihtiyaç	Önerilen
100	1 vCPU / 1–2GB	Render Starter (512MB) yetersiz kalabilir → Hetzner CX22
1.000	2 vCPU / 4GB	Hetzner CX22 (€3,79) — rahat
10.000	4 vCPU / 8GB + Redis + ayrı DB	Hetzner CX32 (€6,80) veya Render Standard
50.000	2× CX32 (yatay) + yönetilen DB + yük dengeleyici	Hetzner çoklu sunucu / bulut ölçekleme

JVM notu: Spring Boot 512MB'ta (Render Starter) sıkışır. Render'da kalacaksanız gerçek kullanım için **Standard (\$25)** gerekir. Fiyat/performansta **Hetzner öne çıkıyor**.

En uygun 3: ① **Hetzner CX22/CX32** (fiyat/performans lideri), ② **Render Starter/Standard** (sıfır yönetim, mevcut kurulum), ③ **Fly.io/Railway** (Frankfurt, kolay).

Birincil öneri: **Hetzner CX22** başlangıç, büyüyünce CX32. Docker Compose zaten hazır (`docker-compose.prod.yml`), tek sunucuda backend+Postgres+Redis çalışır.

8. Veritabanı Maliyeti (PostgreSQL)

Servis	Ücretsiz	Aylık	Depo	Oto-yedek	HA	Konum
Neon	100 CU-saat + 0,5GB	Kullanım bazlı (min yok), storage \$0,35/GB-ay	Esnek	Var (branch/PITR)	Ücretli katman	Frankfurt
Supabase	500MB, 2 proje	\$25 Pro (sabit taban)	8GB dahil	Var (Pro'da PITR)	Add-on	Frankfurt
Railway PG	Kredi içinde	~\$5+	Esnek	Sınırlı	—	EU
Render PG	90 gün deneme	~\$7+	1GB+	Otomatik	Ücretli	Frankfurt
DO Managed PG	—	~\$15	10GB	Otomatik + PITR	+katman	Frankfurt
AWS RDS	12 ay sınırlı	~\$15–30+	Esnek	Otomatik	Multi-AZ	Frankfurt
VPS'te kendi Postgres	—	VPS'e dahil (€0 ek)	Disk	Kendiniz (pg_dump cron)	Yok	VPS'te

Yönetilen DB vs VPS'te Postgres:

- Yönetilen** (Neon/Render/DO): otomatik yedek, PITR, güncelleme, izleme sağlayıcıda; hassas sağlık verisi için **yedek güvencesi** kritik → tavsiye edilir.
- VPS'te self-host:** ek para yok ama yedek/güncelleme/felaket kurtarma tamamen sizde. Sağlık verisi için risklidir.

Başlangıç önerisi: Neon (Launch, kullanım bazlı). Frankfurt, ucuz, otomatik yedek + PITR, branch özelliği staging için ideal. Alternatif: tek-VPS senaryosunda Postgres'i aynı Hetzner sunucusunda çalıştırıp **günlük pg_dump** → **R2/Backblaze** yedeği (Bölüm 17).

9. Domain ve DNS

Uzantı önerisi: Sağlık/destek platformu için **.org** güven ve kâr amacı gütmeyen çağrışımla uygundur; **.com** en tanınık ve profesyoneldir. Türkiye odaklıysanız **.com.tr** yerel güven verir. **Öneri:** **.com** (birincil) + **.org** (koruma) + **gerekliyorsa .com.tr**.

Not: Mevcut kodda `otizmdstek.com` referansları var (VAPID subject), yani muhtemelen **.com** zaten planlı.

Firma	.com ilk yıl	.com yenileme	WHOIS gizlilik	DNS	Transfer	SSL
Cloudflare Registrar	\$10,44	\$10,44 (maliyet fiyatı, artış yok)	Ücretsiz	Mükemmel (ücretsiz)	Ücretsiz	Ücretsiz
Namecheap	~\$10	~\$15	Ücretsiz	İyi	Ucuz	Ücretsiz
GoDaddy	Düşük promo	Yüksek	Çoğu ücretli	Orta	—	Genelde ücretli
Natro / Turhost / Güzel Hosting	~\$12–15 (~560–700 TL)	Benzer	Değişir	İyi	—	Let's Encrypt

.com.tr / .org.tr belge durumu: **TRABİS** sistemiyle (2022 sonrası) **.com.tr**, **.org.tr**, **.net.tr** artık **belgesiz, ilk gelen alır** esasına göre alınabiliyor (kayıt sırasında T.C. kimlik/vergi no bilgisi istenir ama önceden marka/belge ibrazı gerekmez). Fiyat: **.com.tr ~\$1,49/yıl** (~70 TL).

Öneri: Cloudflare Registrar — maliyet fiyatı, yenileme artışı yok, ücretsiz WHOIS gizliliği, en iyi DNS/CDN entegrasyonu. (Cloudflare **.com.tr** satmaz; onu Natro/Turhost'tan alıp DNS'i Cloudflare'e yönlendirirsiniz.)

10. SSL, CDN ve Güvenlik

Hizmet	Maliyet	Değerlendirme
Let's Encrypt	Ücretsiz	Self-host'ta (nginx/Caddy) otomatik yenilenen TLS. Yeterli.
Cloudflare (Free)	\$0	TLS + CDN + temel DDoS + 5 WAF kuralı + Turnstile. Bu proje için fazlasıyla yeterli.
Cloudflare Pro	~\$20/ay	Gelişmiş WAF, image resize. Başlangıçta gerekli .
Ücretli SSL sertifikası	\$50–200/yıl	Gerekli değil — Let's Encrypt/Cloudflare ücretsiz DV sertifikası aynı yeşil kilidi verir.
Cloudflare Turnstile	Ücretsiz	reCAPTCHA yerine — kayıt/iletişim/parola-sıfırlama formlarına bot koruması. Eklenmeli.
reCAPTCHA v3	Ücretsiz	Alternatif ama Google'a veri gider; Turnstile gizlilik açısından daha iyi.

Sonuç: Ücretli SSL **gerekli**. **Ücretsiz Cloudflare paketi yeterli.** Rate limiting kodda zaten var; Cloudflare Free + Turnstile ile bot/spam koruması tamamlanır.

11. Dosya ve Görsel Depolama

Kritik bulgu: Şu an dosyalar **backend'in yerel diskinde** (uploads/) tutuluyor ve /api/upload/{filename} GET'i **herkese açık** (permitAll). Dosya adları rastgele UUID (tahmin edilemez) ama **yetki kontrolü yok** ve **Render'da disk efemeral** → yeniden başlatmada kaybolur, yedeklenmez. Çocuklara ait rapor/belge/fotoğraf için **kabul edilemez** bir üretim durumu.

Servis	Ücretsiz	Depo \$/GB-ay	Egress	İstek	Özel erişim
Cloudflare R2	10GB + 1M/10M işlem	\$0,015	\$0 (ücretsiz!)	A:\$4,5/M, B:\$0,36/M	İmzalı URL
Backblaze B2	10GB	\$0,006	İlk 3x depo ücretsiz	Ucuz	İmzalı URL
AWS S3	12 ay 5GB	~\$0,023	Pahalı ~\$0,09/GB	Var	İmzalı URL
Supabase Storage	1GB	dahil	Plana bağlı	—	RLS/İmzalı
DO Spaces	—	\$5/250GB paket	1TB dahil	—	İmzalı
Cloudinary	Kredi bazlı	—	—	—	Görsel optimizasyon

Herkese açık URL riski: Sağlık raporu/çocuk fotoğrafı gibi belgeler tahmin-edilemez de olsa yetkisiz erişime kapatılmalı. URL sızarsa (log, referrer, paylaşım) herkes erişir. → **İmzalı URL (kısa süreli) + sunucu tarafında sahiplik kontrolü şart.**

Öneri: Cloudflare R2. Egress ücretsiz (indirme trafiği bedava), ucuz depolama, imzalı URL, aynı Cloudflare ekosistemi. Backend'e S3-uyumlu SDK ile bağlanıp FileStorageService 'i R2'ye taşıyın; FileUploadController GET'ini **kaldırıp** imzalı URL üreten yetkili bir endpoint'e çevirin.

12. E-posta Sistemi

İhtiyaç (kodda karşılığı var): e-posta doğrulama, parola sıfırlama (PasswordResetToken , ForgotPasswordPage), hoş geldin, iletişim/başvuru bildirimleri, uzman başvuru bildirimi. Transactional e-posta **gerekli**.

Servis	Ücretsiz	Ücretli	SMTP	API	Domain doğrulama
Brevo	300/gün (~9.000/ay)	\$9/ay (5k)			Gerekli (SPF/DKIM)
Resend	3.000/ay (100/gün)	\$20/ay			Gerekli
Amazon SES	~\$0,10/1.000	Çok ucuz			Gerekli
Mailgun	Deneme	~\$15+			Gerekli
SendGrid	~100/gün	\$19,95+			Gerekli
Postmark	100 deneme	\$15 (10k)			Gerekli

Öneri (başlangıç): Brevo — 300/gün ücretsiz katman başlangıç için yeterli, SMTP destekli (backend spring-boot-starter-mail ile birebir uyumlu, kod değişikliği **gerekmez**, sadece MAIL_HOST/USERNAME/PASSWORD). Hacim artınca **Amazon SES** (en ucuz) veya Resend'e geçin.

Not: `.env.example` şu an SendGrid örneği içeriyor — Brevo SMTP bilgileriyle değiştirmeniz yeterli. Domain'e **SPF + DKIM + DMARC** kaydı şart (teslimat için).

13. Kimlik Doğrulama

Mevcut sistem: Spring Security + JWT (access 15dk + refresh 7gün rotasyonlu) + BCrypt. Bu güvenli, olgun ve ücretsiz bir kurulum. Roller (PARENT/EXPERT/ADMIN/TEACHER) method security ile yönetiliyor.

Seçenek	Maliyet	Spring uyumu	Bakım	Değerlendirme
Mevcut: Spring Security+JWT	\$0	Yerli	Sizde	✅ Koru — güvenli, tam kontrol
Firebase Auth	Ücretsiz kota	Orta	Düşük	Gereksiz geçiş
Supabase Auth	Pro \$25	Orta	Düşük	Gereksiz
Auth0	Ücretsiz→pahalı	SDK	Düşük	Ölçekte pahalı
Clerk	Kullanıcı bazlı	React iyi	Düşük	Gereksiz maliyet
Keycloak	Self-host \$0	İyi	Yüksek	Aşırı mühendislik

Öneri: Mevcut sistemde kalın. Güvenli, çalışıyor, harici bağımlılık yok. İyileştirmeler: (a) token'ı `localStorage` yerine `httpOnly` cookie'ye taşımayı değerlendirin, (b) e-posta doğrulama akışını prod'da zorunlu kılın, (c) "Google ile giriş" **isterseniz** eklenebilir ama zorunlu değil.

Rol yönetimi: Uzman/kurum rolleri **admin onay** ile aktifleşmeli (koddaki `license_verified`, `AdminExpertsPage` mevcut — bu akış var). Sağlık platformunda sahte uzman riskini azaltır.

14. Yönetim Paneli

Mevcut — ve kapsamlı. `frontend/src/pages/admin/` altında: Overview, Analytics, Users, Experts (onay), Articles (içerik moderasyonu), Reports (şikâyet), AuditLog, Settings. Rol korumalı (`AdminRoute`). Backend'de `AdminController` + `AuditLog` .

İstenen özelliklerin karşılığı: kullanıcı yönetimi ✅, pasifleştirme ✅ (`is_active`), içerik/makale yönetimi ✅, uzman onaylama ✅, şikâyet/rapor ✅, denetim kaydı ✅, istatistik ✅, ayarlar ✅.

Eksik olabilecekler: KVKK "kullanıcı silme talebi" iş akışı ve dosya yönetimi ekranı — eklenmesi önerilir.

Yapı: Aynı proje gerekmez — mevcut frontend içinde lazy-load edilen, rol-korumalı bölüm olarak durması doğru; ekstra hosting maliyeti **\$0** (aynı statik site). **Geliştirme maliyeti:** çoğu yapılmış; eksik iş akışları için kendiniz yaparsanız \$0, dışarıdan ~1 haftalık iş.

15. Analitik, Loglama, Hata Takibi

Servis	Ücretsiz	Aylık	Gizlilik	Gereklilik
Sentry	5k hata/ay, 1 kullanıcı	Team \$26	İyi (PII scrub gerekir)	Gerekli (FE+BE hata takibi)
UptimeRobot	50 monitör, 5dk	\$7+	—	Gerekli (uptime)
Plausible	— (self-host \$0)	~\$9 cloud	Çok iyi, çerezsiz, KVKK dostu	Önerilir
Google Analytics 4	Ücretsiz	\$0	Zayıf (rıza gerekir)	Alternatif
Google Search Console	Ücretsiz	\$0	—	Gerekli (SEO)
Better Stack (Logtail)	Sınırlı ücretsiz	~\$25+	İyi	Opsiyonel (log toplama)
Prometheus + Grafana	Self-host \$0	VPS'e dahil	—	Backend zaten Prometheus expose ediyor — Grafana Cloud Free ile bağlanabilir

Hassas veri & loglama: Kod SLF4J kullanıyor. **Kesinlikle:** parola, token, sağlık verisi, çocuk adı loglara yazılmamalı. Sentry'de `beforeSend` ile PII maskeleyme, backend'de request body loglamayı kapatın. `GlobalExceptionHandler`'ın stack trace'i kullanıcıya döndürmediğinden emin olun.

Öneri: Sentry (ücretsiz Developer başlangıç) + UptimeRobot (ücretsiz) + Plausible (KVKK dostu) + Search Console (ücretsiz). Backend Prometheus metriklerini Grafana Cloud Free'ye bağlayın.

16. SEO

Mevcut durum (koddan):

- ✅ `lang="tr"`, tek `<title>` + `meta description`, `theme-color`, PWA manifest.
- ❌ **robots.txt yok, sitemap.xml yok** (`frontend/public/` 'te bulunamadı).
- ❌ **Per-sayfa meta/OG yok** — `react-helmet` benzeri yok; tüm sayfalar aynı başlık/açıklama.
- ❌ **Schema.org / canonical yok.**
- ❌ **SPA client-render** — halka açık içerik (bilgi bankası, tanıtım) için indeksleme zayıf/yavaş.

Yapılacaklar:

- `robots.txt` + `sitemap.xml` ekle (`public/`).
- Sayfa başına dinamik `<title>` / `<meta>` /OG etiketi (`react-helmet-async` veya `react-router meta`).
- Halka açık içerik sayfaları için** prerender/SSG düşün (`vite-plugin-ssr` / `Astro`'ya taşıma veya statik prerender). Auth arkası sayfalar SEO gerektirmez.
- Google Search Console + Analytics/Plausible kur.
- Core Web Vitals: kod-bölme (lazy) zaten var ✅; Google Fonts'u self-host et (`render-blocking` azalt).

17. Yedekleme ve Felaket Kurtarma

İhtiyaç	Çözüm	Tahmini aylık maliyet
Günlük DB yedeği	Yönetilen DB oto-yedek (Neon/Render) veya <code>pg_dump</code> <code>cron</code>	\$0 (yönetilen dahil)
Haftalık tam yedek	R2/Backblaze'e şifreli arşiv	~\$0-1
Dosya yedeği	R2 dayanıklı; ikinci bölgeye replika	~\$0-2
Sunucu snapshot	Hetzner snapshot	~€1,3/ay (~66 TL)
Farklı veri merkezi	R2 + Backblaze (çapraz sağlayıcı)	Düşük
Silinen veri geri alma	DB PITR (Neon/DO)	Plana dahil
Yedekten geri yükleme testi	3 ayda bir manuel test	\$0 (zaman)
Yedek şifreleme	<code>gpg</code> / <code>age</code> ile şifreli yedek	\$0
Saklama süresi	30 gün günlük + 12 ay aylık (KVKK politikasına göre)	—

Kodda bir "veritabanı yedeği oluştur" admin endpoint'i eklenmiş — ancak bu **dış/otomatik yedeğin yerini tutmaz**. Yönetilen DB oto-yedeği + R2'ye şifreli offsite kopya şart. Sağlık verisi için yedek **şifrelenmeli**.

18. Test ve Yayın Süreçleri

Mevcut: Backend 18 test (unit + Testcontainers integration), frontend Vitest + Playwright, 3 GitHub Actions workflow. İyi bir temel var.

Yayın öncesi eklenecekler: yük testi (k6 — `scripts/load-tests/` klasörü zaten var), güvenlik testi (OWASP ZAP), erişilebilirlik testi (axe), yetkilendirme testleri (her rol için endpoint erişim matrisi), dosya yükleme güvenlik testi, yedekten geri yükleme testi.

Ortamlar:

Ortam	Gerekli mi	Açıklama
Local	✓	docker-compose.yml var
Development	✓	Ana branch CI
Test/CI	✓	GitHub Actions (mevcut)
Staging	✓ Ekle	Prod'un birebir kopyası — yayın öncesi son test. Neon branch + Cloudflare Pages preview ile ucuz kurulur
Production	✓	—

Önerilen CI/CD (mevcut yapının üzerine):

1. PR → lint + unit + integration test (backend-ci, frontend-ci — **var**).
2. Merge to `main` → Docker imaj build → GHCR (**var**).
3. **Staging'e otomatik deploy** → smoke test.
4. Manuel onay → production deploy (`DEPLOY_ENABLED=true` ile SSH deploy zaten hazır, ya da Render/Cloudflare otomatik).

19. Toplam Maliyet Tablosu

Aylık maliyetler; yıllık = ×12. Fiyatlar 15 Tem 2026 (1 USD = 47 TL).

Hizmet	Sağlayıcı	Zorunlu?	Kurulum	Aylık	Yıllık	Ücretsiz Alt.	Önerilen
Domain	Cloudflare Registrar	Evet	\$0	~\$0,87	\$10,44 (~491 TL)	—	✓ Cloudflare
DNS	Cloudflare	Evet	\$0	\$0	\$0	✓	Cloudflare
Frontend hosting	Cloudflare Pages	Evet	\$0	\$0	\$0	✓	Cloudflare Pages
Backend hosting	Hetzner CX22	Evet	\$0	~\$4 (€3,79)	~\$48	Render free (uyur)	Hetzner
Veritabanı	Neon Launch	Evet	\$0	~\$5–15 tahmini	~\$60–180	Neon free	Neon
SSL	Let's Encrypt/CF	Evet	\$0	\$0	\$0	✓	Ücretsiz
CDN/WAF	Cloudflare Free	Evet	\$0	\$0	\$0	✓	Cloudflare
Dosya depolama	Cloudflare R2	Evet	\$0	~\$0–2 tahmini	~\$0–24	R2 free 10GB	R2
E-posta	Brevo	Evet	\$0	\$0 (300/gün)	\$0	✓	Brevo
Güvenlik/CAPTCHA	CF Turnstile	Önerilir	\$0	\$0	\$0	✓	Turnstile
Hata takibi	Sentry	Önerilir	\$0	\$0–26	\$0–312	Sentry free	Sentry free→Team
Analitik	Plausible	Önerilir	\$0	~\$9 tahmini	~\$108	GA4 \$0	Plausible
Uptime	UptimeRobot	Önerilir	\$0	\$0	\$0	✓	UptimeRobot
Yedekleme	R2 + snapshot	Evet	\$0	~\$1–3	~\$12–36	—	R2+Hetzner snap
Yönetim paneli	Mevcut FE içinde	—	\$0	\$0	\$0	✓	Ayrı proje gerekmez
Hukuki metinler	KVKK uzmanı/avukat	Evet	~\$300–1.500 tahmini (tek sefer)	—	—	⚠ Şablon riskli	Profesyonel destek
Erişilebilirlik	axe/Lighthouse	—	\$0	\$0	\$0	✓	Ücretsiz araçlar
AI API	Google Gemini	Evet	\$0	~\$0–5 tahmini	~\$0–60	—	flash-lite (ucuz)

20. Üç Bütçe Senaryosu

Senaryo 1 — Minimum maliyetli profesyonel başlangıç (≤ birkaç yüz kullanıcı)

- Frontend: Cloudflare Pages (\$0) · Backend: Hetzner CX22 (€3,79 ≈ \$4) · DB: **Postgres aynı VPS'te** (\$0) + R2'ye günlük yedek · Dosya: R2 free · E-posta: Brevo free · CDN/SSL: Cloudflare free · Hata: Sentry free · Uptime: UptimeRobot free · Domain: \$0,87/ay.
- Aylık: ~\$5–6 (≈ 235–280 TL) · Yıllık: ~\$60–75 (≈ 2.800–3.500 TL)** + tek seferlik hukuki metin.
- Güvenlikten ödün yok; tek geliştirici yönetir (Docker Compose hazır).

Senaryo 2 — Önerilen profesyonel yapı (1.000–10.000 kullanıcı)

- Frontend: Cloudflare Pages (\$0) · Backend: Hetzner CX32 (€6,80 ≈ \$8) · DB: **Neon Launch** (~\$10 tahmini, oto-yedek+PITR) · Dosya: R2 (~\$2) · E-posta: Brevo/SES (~\$0–9) · Sentry Team (\$26) · Plausible (~\$9) · Uptime free · Yedek (~\$2) · Domain (\$0,87).
- Aylık: ~\$60–70 (≈ 2.800–3.300 TL) · Yıllık: ~\$720–840 (≈ 34.000–40.000 TL)** + hukuki metin.

Senaryo 3 — Büyüyen platform (10.000–50.000 kullanıcı)

- Frontend: Cloudflare Pages/Pro · Backend: 2× Hetzner CX32 + yük dengeleyici (~\$20) · DB: Neon Scale / DO Managed HA (~\$40–60) · Redis yönetilen (~\$10) · R2 (~\$5–10) · SES (~\$5) · Sentry Business (\$80) · Plausible (~\$19) · Better Stack log (~\$25) · Staging (~\$10) · Yedek (~\$5).
- Aylık: ~\$220–300 (≈ 10.500–14.000 TL) · Yıllık: ~\$2.600–3.600 (≈ 124.000–170.000 TL).**

21. Nereden Satın Almalıyım?

İşlem	Öneri	Neden
Domain	Cloudflare Registrar (.com \$10,44 sabit)	Maliyet fiyatı, yenileme artışı yok, ücretsiz WHOIS
DNS	Cloudflare	Ücretsiz, hızlı, WAF/Turnstile aynı panelde
Frontend	Cloudflare Pages	Ücretsiz, sınırsız trafik, ticari kısıt yok, saf SPA'ya ideal
Backend	Hetzner CX22→CX32	Fiyat/performans lideri, Docker Compose hazır, TR'ye iyi gecikme
Veritabanı	Neon (veya başlangıçta VPS-içi Postgres)	Oto-yedek+PITR, ucuz, staging için branch
Dosya	Cloudflare R2	Egress ücretsiz, imzalı URL, ucuz
E-posta	Brevo (SMTP)	300/gün ücretsiz, mevcut Spring Mail ile sıfır kod değişikliği
SSL	Let's Encrypt / Cloudflare	Ücretsiz, otomatik
CDN	Cloudflare Free	Yeterli
Yedekleme	Neon oto-yedek + R2'ye şifreli offsite	Sağlık verisi güvencesi
Loglar	Backend Prometheus + Grafana Cloud Free ; app logları stdout	Ücretsiz, mevcut altyapı
Hata takibi	Sentry	FE+BE, PII maskeleye
İzleme	UptimeRobot (ücretsiz)	Uptime + durum sayfası
Yönetim paneli	Mevcut frontend içinde	Ekstra hosting yok

22. Adım Adım Yayınlama Rehberi

#	İşlem	Servis	Maliyet	Zorluk	Kod değişikliği	Kontrol
1	Kritik güvenlik: alan şifreleme, dosya erişimi	—	\$0	Yüksek	AttributeConverter; upload GET'i yetkiliye çevir	Şifreli kolon, imzalı URL çalışıyor
2	Prod env değişkenleri	.env	\$0	Düşük	.env.example 'ı doldur (güçlü JWT/ENCRYPTION/admin)	StartupSecurityCheck prod'da geçiyor
3	Veritabanı servisi	Neon	~\$0–10	Düşük	DATABASE_URL	Flyway V1–V42 migrate oldu
4	Backend Docker	(hazır)	\$0	Düşük	—	İmaj GHCR'a push
5	Backend sunucuya kur	Hetzner	~\$4	Orta	docker-compose.prod.yml	/actuator/health 200
6	Domain al	Cloudflare/Natro	~\$10/yıl	Düşük	—	Domain aktif
7	DNS yapılandır	Cloudflare	\$0	Düşük	—	A/CNAME çözülüyor
8	Frontend yayınla	Cloudflare Pages	\$0	Düşük	vercel.json → _redirects uyarla	Site açılıyor
9	API subdomain	Cloudflare	\$0	Düşük	CORS_ORIGINS , api.domain	Frontend→API bağlanıyor
10	HTTPS	Cloudflare/LE	\$0	Düşük	—	Yeşil kilit
11	E-posta domain doğrulama	Brevo	\$0	Orta	SPF/DKIM/DMARC	Test maili gelen kutusuna düşüyor
12	Dosya depolama bağla	R2	~\$0	Yüksek	FileStorageService →R2 SDK	Yükle/imzalı-indir çalışıyor
13	DB yedekleme	Neon/R2	~\$1	Düşük	cron script	Geri yükleme testi başarılı
14	Hata takibi	Sentry	\$0	Orta	Sentry SDK (FE+BE) + PII scrub	Test hatası Sentry'de
15	Analitik	Plausible/GSC	~\$0–9	Düşük	script tag + sitemap	Ziyaret görünüyor
16	Erişilebilirlik testi	axe/Lighthouse	\$0	Orta	a11y düzeltmeleri	Skor ≥ 90
17	Güvenlik testi	OWASP ZAP	\$0	Orta	tespit düzeltmeleri	Kritik bulgu yok
18	KVKK & yasal metinler	Avukat/KVKK uzmanı	~\$300–1.500 tahmini	Orta	/kvkk /gizlilik /kullanım /tibbi-uyari içeriği + VERBİS	Metinler onaylı
19	Staging testi	Neon branch + Pages preview	~\$0	Orta	—	Uçtan uca akışlar geçti
20	Production	—	—	Düşük	—	Canlı, izleniyor

23. Nihai Öneri

Uygulanabilir Sistem Mimarisi

Katman	Öneri
Frontend	Cloudflare Pages (React SPA, ücretsiz, global CDN)
Backend	Hetzner CX22 → büyüyünce CX32 (Docker Compose: Spring Boot + Redis)
Veritabanı	Neon PostgreSQL (Launch, oto-yedek + PITR) — ya da başlangıçta aynı VPS'te Postgres
Domain	Cloudflare Registrar .com (+ .org koruma, gerekiyorsa .com.tr)
DNS ve CDN	Cloudflare (Free)
SSL	Let's Encrypt / Cloudflare (ücretsiz)
Dosya depolama	Cloudflare R2 + imzalı URL + sahiplik kontrolü
E-posta	Brevo (SMTP, mevcut Spring Mail ile uyumlu)
Kimlik doğrulama	Mevcut Spring Security + JWT (değiştirme)
Hata takibi	Sentry (FE+BE, PII maskeli)
Loglama	stdout + Prometheus/Grafana Cloud Free
Analitik	Plausible (KVKK dostu) + Google Search Console
Yedekleme	Neon oto-yedek + R2'ye şifreli offsite + Hetzner snapshot
Sunucu izleme	UptimeRobot + Grafana
Yönetim paneli	Mevcut frontend içinde (ek maliyet yok)
CI/CD	GitHub Actions (mevcut 3 workflow) + staging + onaylı prod deploy
Tahmini aylık toplam	Senaryo 2 için ~\$60–70 (≈ 2.800–3.300 TL)
Tahmini yıllık toplam	~\$720–840 (≈ 34.000–40.000 TL) + tek seferlik hukuki metin (~\$300–1.500 tahmini)

Şimdi mutlaka yapılması gerekenler

- Alan bazlı şifreleme — sağlık/çocuk verisini AES ile şifrele (ENCRYPTION_KEY zaten var ama kullanılmıyor).
- Dosya erişim güvenliği — /api/upload GET public'ini kaldır, R2 + imzalı URL + sahiplik kontrolü.
- Kalıcı & yedekli depolama — dosyaları yerel diskten R2'ye taşı (aksi halde Render'da kaybolur).
- Yönetilen DB + otomatik yedek.
- Güçlü prod secret'lar ve rotasyon.
- KVKK/yasal metinler + VERBİS — uzman desteğiyle (sayfalar hazır, içerik hukukçu onaylı olmalı).
- AI/tarama/BEP ekranlarına görünür tıbbi uyarı.

İlk 3 ay içinde yapılabilecekler

- Sentry + UptimeRobot + Plausible + Search Console kurulumu.
- SEO: robots.txt, sitemap, per-sayfa meta; halka açık sayfalar için prerender.
- Turnstile ile bot koruması (kayıt/iletişim/parola-sıfırlama).
- Token'ı httpOnly cookie'ye taşımayı değerlendir; CSP başlıkları.
- Erişilebilirlik: axe/Lighthouse taraması + odak yönetimi + prefers-reduced-motion yaygınlaştır.
- Kullanıcıya dönük veri dışı aktarma + hesap silme akışı (KVKK m.11).
- Staging ortamı + otomatik deploy.

Kullanıcı sayısı arttığında

- Hetzner CX32 / çoklu sunucu + yük dengeleyici; yönetilen Redis.
- DB'yi HA katmanına (Neon Scale / DO Managed) yükselt.
- Better Stack ile merkezi log; Grafana dashboard.
- Yük testi (k6 — scripts/load-tests/ hazır) ve ölçekleme planı.
- CDN görsel optimizasyonu (R2 + Cloudflare Images).

● Şimdilik gereksiz masraflar

- Vercel Pro (\$20) — Cloudflare Pages ücretsiz yeterli.
- Cloudflare Pro (\$20) — Free paket yeterli.
- Ücretli SSL sertifikası — Let's Encrypt aynı işi görür.
- Auth0/Clerk/Keycloak — mevcut JWT güvenli.
- AWS/GCP/Azure — bu ölçekte gereksiz pahalı (egress).
- Ayrı admin paneli projesi — mevcut yapı yeterli.

Özet

Bu proje "demo" değil — güvenlik, mimari ve test tarafında beklenenden çok daha olgun (Flyway V1-V42, rate limiting, audit log, method security, kapsamlı admin paneli, a11y emeği). Profesyonel yayın için **4 gerçek teknik boşluk** kritik:

1. **Kullanılmayan şifreleme** (hassas veriler düz metin)
2. **Herkese açık dosya sunumu** (yetki kontrolü yok)
3. **Efemeral/yedeksiz dosya depolama** (yeniden başlatmada kayıp)
4. **Hata takibi/monitoring eksikliği**

Bunlar kapatıldığında, aylık ~\$5–70 arası bir bütçeyle güvenli ve profesyonel biçimde yayına alınabilir. **Sağlık verisi işlediği için KVKK uzmanı/avukat desteği pazarlık konusu değildir.**

Kaynaklar (fiyatlandırma, 15 Temmuz 2026)

- TradingEconomics — USD/TRY: <https://tradingeconomics.com/turkey/currency>
- Hetzner Cloud: <https://www.hetzner.com/cloud/>
- Render Pricing: <https://render.com/pricing>
- Vercel Pricing: <https://vercel.com/pricing>
- Neon Pricing: <https://neon.com/pricing>
- Supabase Pricing: <https://supabase.com/pricing>
- Cloudflare R2: <https://developers.cloudflare.com/r2/pricing/>
- Cloudflare Registrar: <https://www.cloudflare.com/products/registrar/>
- Resend Pricing: <https://resend.com/pricing>
- Brevo Pricing: <https://www.brevo.com/pricing/>
- Sentry Pricing: <https://sentry.io/pricing/>
- UptimeRobot Pricing: <https://uptimerobot.com/pricing/>
- Natro .com.tr: <https://www.natro.com/domain-sorgulama/com-tr-domain-kayit>
- Turhost belgesiz .com.tr: <https://www.turhost.com/domain/belgesiz-com-tr/>